Лабораторна робота № 2

Тема: «Дослідження реалізацій протоколів IPsec».

Індивідуальний варіант: сценарій 2 — підключення віддаленого працівника.

Виконали: Остаповець Олеся Віталіївна та Булигін Олексій Михайлович, група ФІ-52мн.

Мета роботи та використані засоби

Мета роботи — дослідити архітектуру та криптографічні механізми IPsec, принципи організації захищених мережевих з'єднань та особливості застосування IPsec у різних мережевих сценаріях.

Робота має аналітичний характер. Відповіді ґрунтуються на стандартах IETF, що визначають архітектуру IPsec, ESP, AH, IKEv2 і NAT Traversal, на чинних вимогах до криптографічних алгоритмів [6–8] та на специфікації WireGuard [10–11]. Перелік джерел наведено в кінці звіту. Матеріали опрацьовано станом на 30.10.2026.

1. Дослідження основних механізмів IPsec

1.1. Призначення IPsec і рівень функціонування

IPsec захищає IP-пакети на мережевому рівні (L3 моделі OSI, рівень Інтернету в TCP/IP). Він забезпечує конфіденційність, цілісність, автентифікацію джерела даних, захист від повторного відтворення та контроль доступу за політикою [1].

Оскільки захист працює нижче транспортного рівня, він прозорий для застосунків: TCP, UDP, ICMP та будь-які інші протоколи захищаються без змін у програмах. На відміну від TLS, захищається трафік між вузлами або мережами, а не окремий сеанс застосунку.

1.2. Функції IKEv2 та ESP і їх взаємодія

IKEv2 — протокол керування (control plane). Він виконує взаємну автентифікацію сторін (сертифікати, PSK або EAP), узгоджує алгоритми, проводить обмін Діффі–Геллмана, формує ключовий матеріал, створює, оновлює та видаляє SA [4]. IKEv2 працює поверх UDP, порти 500 і 4500.

ESP — протокол передавання даних (data plane). Він шифрує та автентифікує кожен пакет ключами, які сформував IKEv2; номер протоколу IP — 50 [2].

Послідовність взаємодії [4]:

1. IKE_SA_INIT: сторони узгоджують алгоритми, обмінюються частками DH і nonce; формується IKE SA, далі повідомлення IKE шифруються.
2. IKE_AUTH: сторони передають ідентичності й доказ автентичності (AUTH), узгоджують traffic selectors і створюють першу пару Child SA для ESP.
3. Передавання даних: ESP захищає пакети ключами Child SA, отриманими з SKEYSEED через prf+.
4. CREATE_CHILD_SA: оновлення ключів або створення додаткових Child SA до завершення строку дії; INFORMATIONAL — перевірка живості та видалення SA.

1.3. Security Association

SA — односпрямоване логічне з'єднання, для якого визначено набір параметрів захисту. Вхідну SA ідентифікує SPI разом із протоколом (ESP/AH) [1]. SA характеризують:

- алгоритми та ключі шифрування й цілісності;
- режим (транспортний або тунельний) та адреси кінцевих точок тунелю;
- лічильник послідовності та вікно захисту від повторного відтворення;
- traffic selectors — який трафік дозволено передавати через SA;
- строк дії в секундах або байтах.

Оскільки SA односпрямована, для двостороннього обміну потрібна щонайменше пара Child SA: по одній на кожен напрямок, з окремими ключами. Окремо існує IKE SA, яка захищає службовий канал IKEv2. Якщо для різних класів трафіку діють різні політики, створюються додаткові пари SA.

1.4. SPD та SAD

SPD (Security Policy Database) задає, що робити з пакетом. За селекторами (адреси, протокол, порти) пакет потрапляє під одну з дій: PROTECT, BYPASS або DISCARD; для PROTECT політика задає вимоги до захисту [1].

SAD (Security Association Database) містить параметри активних SA: ключі, алгоритми, лічильники, строки дії. Для вихідного пакета реалізація за SPD визначає потребу в захисті, а потім вибирає SA з SAD. Для вхідного пакета SA знаходиться за SPI, а після розшифрування перевіряється, що пакет відповідає політиці цієї SA. Третя база, PAD, пов'язує автентифіковані в IKE ідентичності з дозволеними політиками [1].

1.5. Транспортний і тунельний режими

У транспортному режимі захищається вміст початкового IP-пакета, а початковий IP-заголовок зберігається. Режим застосовують між двома вузлами, які самі є кінцевими точками обміну: сервер–сервер, хост–хост.

У тунельному режимі весь початковий пакет разом із заголовком інкапсулюється в новий IP-пакет. Зовнішній заголовок містить адреси кінцевих точок тунелю, а внутрішні адреси та протоколи приховані [1]. Режим застосовують між шлюзами (site-to-site), для віддаленого доступу та всюди, де кінцева точка IPsec не збігається з кінцевою точкою обміну.

1.6. Відмінності AH та ESP

AH забезпечує цілісність і автентифікацію пакета, включно з незмінними полями IP-заголовка, але не шифрує дані [3]. ESP забезпечує конфіденційність і цілісність; захищає вміст пакета, але не зовнішній IP-заголовок [2].

ESP переважає з трьох причин. Перша: конфіденційність потрібна майже завжди, а AEAD-алгоритми (AES-GCM, ChaCha20-Poly1305) дають шифрування й цілісність однією операцією. Друга: ESP з алгоритмом NULL покриває випадок, коли потрібна лише цілісність. Третя: AH несумісний з NAT, бо захищає IP-адреси, які NAT змінює. Архітектура IPsec вимагає підтримки ESP (MUST), а підтримку AH залишає необов'язковою (MAY) [1]; для ESP рекомендовано AEAD-алгоритми [6].

1.7. NAT і NAT Traversal

NAT змінює IP-адреси, а NAPT — ще й порти. Це створює три проблеми [12]:

- ESP не має портів, тому NAPT не може розрізнити кілька клієнтів за однією зовнішньою адресою;
- AH стає невалідним після зміни адреси;
- у транспортному режимі контрольні суми TCP/UDP залежать від IP-адрес, які змінює NAT.

NAT-T розв'язує ці проблеми так. У IKE_SA_INIT сторони надсилають NAT_DETECTION_SOURCE_IP і NAT_DETECTION_DESTINATION_IP — хеші своїх адрес і портів. Невідповідність виявляє NAT, і після цього обмін переходить на UDP 4500 [4]. ESP-пакети інкапсулюються в UDP 4500, тому NAT може обробляти їх як звичайний UDP-трафік [5]. Періодичні NAT-keepalive підтримують запис у таблиці трансляції. AH через NAT не працює навіть з NAT-T.

1.8. Perfect Forward Secrecy в IPsec

PFS означає, що компрометація довгострокових секретів (приватного ключа сертифіката чи PSK) або ключів одного сеансу не розкриває інші сеанси. IKE SA завжди створюється з ефемерним DH, тому записаний трафік не розкривається навіть після витоку ключа сертифіката.

Для Child SA це не так очевидно. Перша Child SA та Child SA, оновлені без DH, отримують ключі з SK_d IKE SA. Тому витік SK_d розкриває всі такі SA. PFS для Child SA вмикають окремо: CREATE_CHILD_SA містить додатковий обмін KE, і нові ключі не виводяться лише з попередніх [4]. PFS не захищає від компрометації вузла під час роботи, коли зловмисник читає поточні ключі з пам’яті.

2. Аналіз сценаріїв застосування IPsec

У чотирьох сценаріях із п’яти кінцевою точкою IPsec є шлюз, а не вузол обміну, тому обрано тунельний режим. Транспортний режим доцільний лише для зв’язку двох серверів. Зведені рішення наведено в таблиці 1, схеми та обґрунтування — у пп. 2.1–2.5.

Таблиця 1 — Рішення для сценаріїв застосування IPsec

Сценарій	Кінцеві точки IPsec	Режим	Захищений трафік
1. Два офіси	Шлюз A ↔ шлюз B	Тунельний	LAN A ↔ LAN B на ділянці Інтернету
2. Віддалений працівник	Пристрій працівника ↔ VPN-шлюз	Тунельний	Від пристрою до шлюзу; уся мережа (full tunnel) або лише внутрішні підмережі (split tunnel)
3. Два сервери	Сервер A ↔ сервер B	Транспортний	Увесь або визначений трафік між двома IP-адресами
4. Центр і філії	Шлюз кожної філії ↔ шлюз ЦО	Тунельний	LAN філії ↔ LAN ЦО на ділянках Інтернету
5. LAN і хмара	Локальний шлюз ↔ VPN-шлюз хмари	Тунельний	Локальні підмережі ↔ підмережі хмарної мережі

2.1. З'єднання двох офісів

```
LAN A → Шлюз A ⇄ Інтернет (ESP-тунель) ⇄ Шлюз B → LAN B
```

Кінцеві точки — шлюзи A і B. Режим тунельний: шлюзи захищають пакети від імені робочих станцій, тому на станціях нічого не встановлюється. Traffic selectors обмежують тунель трафіком між підмережами LAN A і LAN B. Захищено цей трафік на ділянці Інтернету; всередині офісних мереж він передається як звичайно. Зовнішній заголовок містить лише публічні адреси шлюзів, тому внутрішня адресація прихована.

2.2. Підключення віддаленого працівника

```
Ноутбук (IKEv2-клієнт) ⇄ Wi-Fi / NAT ⇄ Інтернет (ESP у UDP 4500) ⇄ VPN-шлюз →
LAN організації
```

Кінцеві точки — пристрій працівника та VPN-шлюз організації. Режим тунельний: клієнт отримує внутрішню адресу від шлюзу і звертається до внутрішніх ресурсів так, ніби він в офісі. Захищено трафік між пристроєм і шлюзом: або весь, або лише до внутрішніх підмереж. Шлюз автентифікує саме користувача, а не мережу. Детальний аналіз наведено в розділі 3.

2.3. Захищений зв'язок між двома серверами

```
Сервер A ⇄ недовірена мережа (ESP, транспортний режим) ⇄ Сервер B
```

Кінцеві точки — самі сервери. Обрано транспортний режим: сервери одночасно є кінцевими точками IPsec і обміну, тому новий IP-заголовок не потрібен, а накладні витрати менші. Політика SPD охоплює трафік між двома IP-адресами — увесь або лише потрібні протоколи й порти. Захист наскрізний між вузлами, без довіреного проміжного шлюзу. Якщо між серверами є NAT, застосовують тунельний режим або NAT-T.

2.4. Центральний офіс та декілька філій

```
LAN Ф1 → Шлюз Ф1 ⇄ Інтернет ⇄
LAN Ф2 → Шлюз Ф2 ⇄ Інтернет ⇄  Шлюз ЦО → LAN ЦО
LAN Ф3 → Шлюз Ф3 ⇄ Інтернет ⇄
```

Кінцеві точки — шлюз кожної філії та шлюз ЦО; для кожної філії встановлюється окрема IKE SA та власні Child SA. Режим тунельний, як у сценарії 1. Захищено трафік між LAN кожної філії та LAN ЦО на ділянці Інтернету. Топологія «зірка»

потребує n тунелів замість n(n−1)/2 у повнозв’язній мережі. Доступ між філіями, якщо він дозволений, проходить через шлюз ЦО, і там централізовано застосовується політика.

2.5. Локальна мережа та хмарна інфраструктура

```
LAN → Локальний шлюз ⇄ Інтернет (ESP-тунель) ⇄ VPN-шлюз хмари → Хмарна мережа (VPC/VNet)
```

Кінцеві точки — шлюз організації та VPN-шлюз хмарного провайдера (керований сервіс або власна віртуальна машина). Режим тунельний: з’єднуються дві мережі, а не окремі вузли. Захищено трафік між локальними й хмарними підмережами на ділянці Інтернету. Керовані хмарні VPN-сервіси зазвичай реалізують саме IPsec/IKEv2, тому цей варіант не потребує додаткового ПЗ у хмарі. Для відмовостійкості доцільно мати два тунелі.

3. Детальний аналіз сценарію 2: віддалений працівник

Працівник підключається з ноутбука через публічну мережу (домашній Wi-Fi, мобільний оператор, готель) до VPN-шлюзу на периметрі мережі організації. Пристрій працює як IKEv2-клієнт; шлюз автентифікує користувача й надає йому внутрішню адресу.



Рисунок 1 — Схема підключення віддаленого працівника

Усі SA встановлюються між ноутбуком і шлюзом; ділянка від шлюзу до внутрішніх серверів засобами IPsec не захищена.

3.1. Вибір режиму

Обрано тунельний режим. Кінцеві точки обміну — ноутбук і внутрішні сервери, а кінцеві точки IPsec — ноутбук і шлюз; вони не збігаються, тому потрібна інкапсуляція. Внутрішній пакет має внутрішню адресу клієнта, видану шлюзом через Configuration Payload IKEv2 [4], та адресу внутрішнього сервера. Зовнішній

пакет має публічну адресу клієнта (або його NAT) і адресу шлюзу. Транспортний режим не дозволив би шлюзу маршрутизувати пакети до внутрішніх вузлів від імені клієнта.

3.2. Між якими вузлами встановлюються SA

Усі SA встановлюються між ноутбуком і VPN-шлюзом:

- одна IKE SA — двоспрямований захищений канал керування IKEv2;
- щонайменше одна пара Child SA (ESP): ноутбук → шлюз і шлюз → ноутбук, з окремими SPI та ключами.

Між шлюзом і внутрішніми серверами SA немає: там трафік передається відкрито в межах довіреної мережі.

3.3. Роль IKEv2

1. IKE_SA_INIT: узгодження алгоритмів, ефемерний обмін DH, nonce; виявлення NAT за NAT_DETECTION-повідомленнями.
2. IKE_AUTH: шлюз автентифікується сертифікатом, клієнт перевіряє його ланцюжок та ідентичність. Користувач автентифікується сертифікатом пристрою або через EAP, що дозволяє використати корпоративний каталог і MFA [4].
3. Конфігурація: через CP-запит клієнт отримує внутрішню IP-адресу та DNS-сервери; traffic selectors визначають, чи весь трафік іде в тунель.
4. Супровід: CREATE_CHILD_SA оновлює ключі (з додатковим KE для PFS), DPD перевіряє живість сторін. MOBIKE дозволяє зберегти SA при зміні адреси клієнта, наприклад при переході з Wi-Fi на мобільну мережу [9].

3.4. Функції ESP

ESP у тунельному режимі захищає кожен пакет між ноутбуком і шлюзом [2]:

- конфіденційність: шифрується весь внутрішній пакет — внутрішні адреси, порти, протоколи та дані;
- цілісність і автентичність джерела: тег AEAD (наприклад, AES-GCM) підтверджує, що пакет надіслала сторона з ключем цієї SA і його не змінено;
- захист від повторного відтворення: шлюз відкидає пакети з уже баченим або застарілим номером послідовності;
- контроль доступу: після розшифрування шлюз перевіряє, що пакет відповідає traffic selectors SA.

3.5. Що бачить сторонній спостерігач

Спостерігач у тій самій публічній мережі або в Інтернеті бачить:

- публічні IP-адреси клієнта (або його NAT) і шлюзу — тобто факт підключення до VPN організації;
- порти UDP 500 і 4500, SPI та номери послідовності ESP;
- розміри й часові характеристики пакетів, обсяг трафіку, час сеансу.

Засобами IPsec захищено: внутрішні адреси клієнта й серверів, протоколи, порти, вміст обміну, а після IKE_SA_INIT — ідентичності та сертифікати в IKE_AUTH. У режимі split tunnel трафік, що не йде в тунель (наприклад, звичайний вебперегляд), лишається видимим для локальної мережі.

3.6. NAT і NAT-T

NAT тут майже неминучий: домашні маршрутизатори та мобільні оператори (CGNAT) транслюють адреси й порти. Тому NAT-T необхідний [5]. IKEv2 виявляє NAT в IKE_SA_INIT, переходить на UDP 4500 та інкапсулює ESP в UDP. Клієнт надсилає NAT-keepalive, щоб трансляція не зникла під час простою. Шлюз відповідає на адресу й порт, з яких фактично надійшли пакети. Для шлюзу корисно мати публічну адресу без NAT; якщо він сам за NAT, потрібне перенаправлення портів UDP 500 і 4500.

3.7. Від яких загроз захищає IPsec і від яких — ні

Усуваються:

- перехоплення трафіку в публічних мережах (відкритий Wi-Fi, недовірений провайдер);
- модифікація та підміна пакетів на шляху;
- повторне відтворення перехоплених пакетів;
- підміна VPN-шлюзу за умови коректної перевірки його сертифіката;
- доступ до внутрішніх ресурсів без автентифікації користувача.

Не усуваються самим IPsec:

- компрометація пристрою працівника: шкідливе ПЗ отримує доступ до внутрішньої мережі через легітимний тунель;
- викрадені облікові дані, якщо немає MFA або прив’язки до пристрою;
- загрози на ділянці шлюз → внутрішні сервери та дії зловмисного інсайдера;
- аналіз трафіку за метаданими (п. 3.5) та DoS-атаки на шлюз;

- витоки трафіку в обхід тунелю при split tunnel або неправильно налаштованому DNS.

Тому IPsec доповнюють захистом кінцевих пристроїв, MFA і сегментацією доступу у внутрішній мережі.

4. Порівняння IPsec та WireGuard

IPsec/IKEv2 — гнучкий стандартизований набір протоколів з узгодженням алгоритмів і корпоративною автентифікацією. WireGuard — мінімалістичний протокол із фіксованою криптографією та простою конфігурацією. Порівняння наведено в таблиці 2.

Таблиця 2 — Порівняння IPsec/IKEv2 та WireGuard

Критерій	IPsec/IKEv2	WireGuard
Загальна архітектура	Окремі протоколи керування (IKEv2, UDP 500/4500) і передавання (ESP); політики в SPD, параметри в SAD; зазвичай IKE-демон у просторі користувача, ESP у ядрі [1, 4]	Один протокол поверх UDP; віртуальний мережевий інтерфейс; cryptokey routing — відповідність публічного ключа peer дозволеним IP-адресам (AllowedIPs) [10]
Встановлення та керування ключами	IKEv2: ефемерний DH, взаємна автентифікація сертифікатами X.509, PSK або EAP; оновлення ключів за строком дії; PKI та відкликання сертифікатів [4]	Handshake за схемою Noise IK з ефемерним обміном, оновлення ключів приблизно кожні 2 хв; статичні ключі Curve25519 розповсюджуються вручну або сторонніми засобами; PKI та автентифікації користувача немає [10, 11]
Криптографічні алгоритми	ESP: AES-GCM, ChaCha20-Poly1305, AES-CBC з HMAC-SHA2; DH: групи MODP від 2048 біт, ECP, Curve25519; підписи RSA, ECDSA, EdDSA [6, 7]	Curve25519, ChaCha20-Poly1305, BLAKE2s, SipHash24, HKDF; опційний додатковий PSK [11]

Критерій	IPsec/IKEv2	WireGuard
Вибір алгоритмів	Так: сторони узгоджують набори пропозицій; застарілі алгоритми поступово виводяться з ужитку [6–8]	Ні: набір фіксований, зміна можлива лише новою версією протоколу; немає ризику downgrade через узгодження
Робота з NAT	Потребує NAT-T: виявлення NAT, ESP в UDP 4500, keepalive; MOBIKE для зміни адреси клієнта [4, 5, 9]	Працює поверх UDP від початку; роумінг за адресою останнього автентифікованого пакета; опційний PersistentKeepalive [10]
Складність конфігурації	Висока: багато параметрів, політик і режимів; можливі проблеми сумісності між вендорами	Низька: ключова пара та кілька рядків конфігурації на кожного peer
Типові сценарії	Site-to-site між різнорідним мережевим обладнанням; керовані хмарні VPN; віддалений доступ із корпоративною автентифікацією та вбудованими клієнтами ОС	Віддалений доступ для невеликих команд; з'єднання серверів; overlay-мережі; маршрутизатори на Linux

Вибір для сценаріїв розділу 2

1. **Два офіси — IPsec.** Офісні шлюзи та маршрутизатори підтримують IPsec штатно, а стандарт гарантує сумісність обладнання різних виробників. WireGuard доцільний, якщо обидва шлюзи — Linux-системи під контролем організації.
2. **Віддалений працівник — обидва варіанти.** IPsec/IKEv2 кращий для інтеграції з корпоративним каталогом, MFA через EAP і вбудованими клієнтами ОС. WireGuard простіший і швидше відновлюється при зміні мережі, але видачу й відкликання ключів доведеться організувати окремо.
3. **Два сервери — WireGuard або IPsec.** WireGuard легко налаштувати між двома вузлами, і він має невелику кодову базу. IPsec у транспортному режимі підходить, якщо не потрібен окремий інтерфейс або цього вимагає політика.

4. **Центр і філії — переважно IPsec.** Централізована PKI та сумісність шлюзів різних філій важливіші за простоту. WireGuard можливий за однорідного обладнання, але ручне керування ключами погано масштабується.
5. **LAN і хмара — IPsec.** Керовані хмарні VPN-шлюзи зазвичай підтримують саме IPsec/IKEv2. WireGuard потребує власної віртуальної машини в хмарі та її супроводу.

Висновки

IPsec захищає трафік на мережевому рівні прозоро для застосунків. Протокол розділено на керування (IKEv2: автентифікація, узгодження алгоритмів, формування й оновлення ключів) і передавання даних (ESP: шифрування, цілісність, захист від повторного відтворення). SA односпрямовані, тому двосторонній обмін потребує пари Child SA; SPD визначає, який трафік захищати, а SAD зберігає параметри захисту. AH у сучасних мережах практично витіснений ESP, зокрема через несумісність із NAT; проблему NAT для ESP усуває NAT-T. PFS для Child SA потребує окремого обміну KE під час оновлення ключів.

Тунельний режим підходить для з'єднань, де кінцевою точкою IPsec є шлюз: офіси, філії, хмара, віддалений доступ. Транспортний режим — для прямого зв'язку двох вузлів. Для віддаленого працівника IPsec із NAT-T захищає зміст і внутрішню адресацію в публічних мережах, але не захищає від компрометації пристрою, викрадення облікових даних і аналізу метаданих. WireGuard простіший і має фіксовану сучасну криптографію, проте IPsec залишається кращим вибором для різнорідного обладнання, хмарних шлюзів і корпоративної автентифікації.

Використані джерела

1. RFC 4301 — Security Architecture for the Internet Protocol
2. RFC 4303 — IP Encapsulating Security Payload (ESP)
3. RFC 4302 — IP Authentication Header
4. RFC 7296 — Internet Key Exchange Protocol Version 2 (IKEv2)
5. RFC 3948 — UDP Encapsulation of IPsec ESP Packets
6. RFC 8221 — Cryptographic Algorithm Implementation Requirements and Usage Guidance for ESP and AH
7. RFC 8247 — Algorithm Implementation Requirements and Usage Guidance for IKEv2
8. RFC 9395 — Deprecation of the IKEv1 Protocol and Obsoleted Algorithms
9. RFC 4555 — IKEv2 Mobility and Multihoming Protocol (MOBIKE)

10. J. A. Donenfeld — WireGuard: Next Generation Kernel Network Tunnel
11. WireGuard — Protocol & Cryptography
12. RFC 3715 — IPsec-Network Address Translation (NAT) Compatibility Requirements